FC Fluxo de Caixa

DOCUMENTO 14

CI/CD e qualidade

Pipeline, ferramentas de qualidade e segurança e GitOps

PROJETO

Fluxo de Caixa — Desafio de Arquiteto de Soluções

AUTOR

Bruno Aquino

DATA

11/11/2026

REPOSITÓRIO

github.com/brunoaquino/fluxo-caixa

Java 25 · Spring Boot 4 · AWS ECS Fargate · Terraform · C4 · DDD · ADRs

Sumário

1. O pipeline 3

2. O que o pipeline de aplicação faz 4

3. O que o pipeline de infra faz 4

4. O que ainda pode entrar, e por quê 5

5. ECS e EKS, lado a lado 7

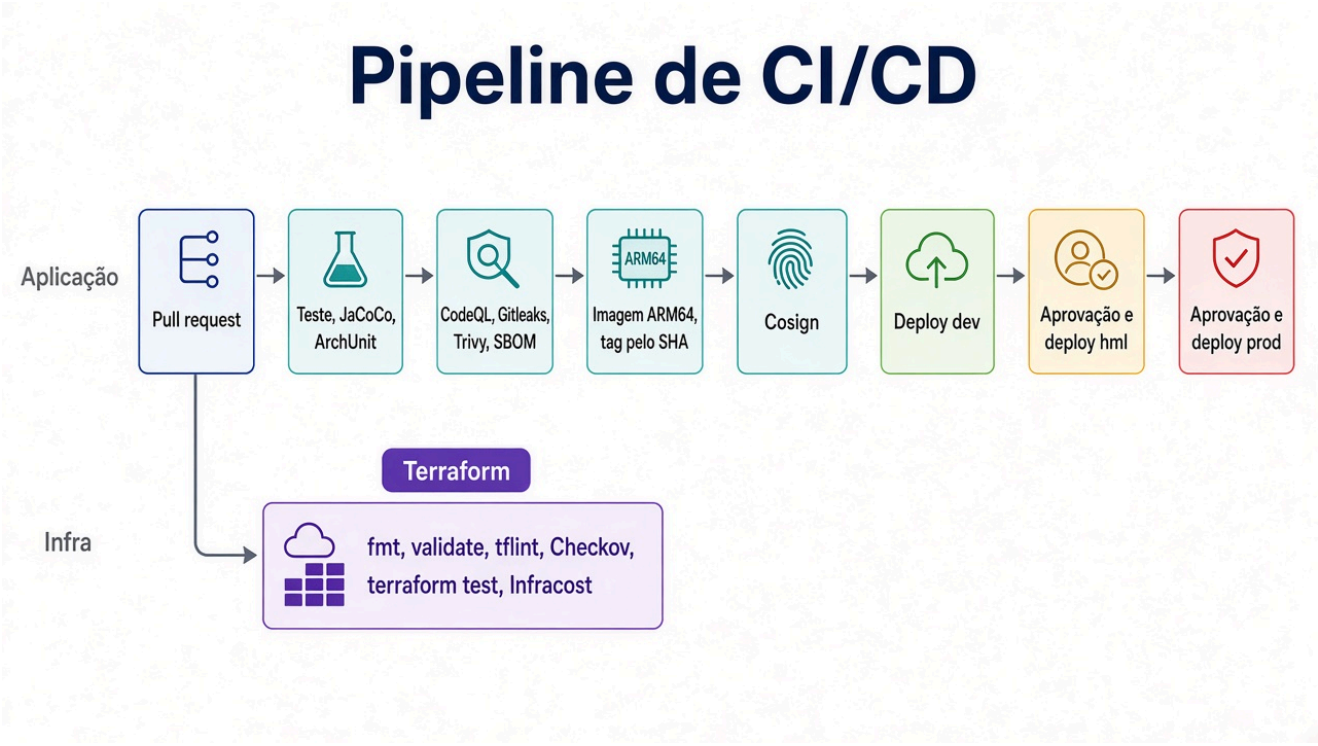
FONTE: DOCUMENTOS-BRUTOS/14-CICD-E-QUALIDADE.MD

14 — CI/CD e qualidade

Contrato do pipeline desta entrega: build uma vez, a mesma imagem promove dev → hml → prod, e o que entra em prod passou por teste, análise e uma aprovação humana. O scheduler de hoje é ECS (ADR 0020). GitOps entra com o EKS (ADR 0028).

Conferência com o YAML em 2026-11-10. O CI (`.github/workflows/ci.yml`) roda `./mvnw verify` com JaCoCo, Trivy na imagem ARM64 (`ignore-unfixed` , HIGH/CRITICAL com correção quebram), SBOM CycloneDX, CodeQL, Gitleaks e dependency-review. SonarCloud entra só quando existem `SONAR_TOKEN` e `vars.SONAR_ORGANIZATION` ; sem isso o job segue verde. O workflow de Terraform faz `fmt` , `validate` em dev, hml, prod e bootstrap, tflint, Checkov, Trivy config, `terraform test` e Infracost. O CD (`.github/workflows/cd.yml`) só começa se `vars.AWS_CD_ENABLED` for `true` . Região `us-east-1` . Push na `main` publica em dev; hml e prod saem por `workflow_dispatch` , com a mesma imagem copiada por digest e assinada com Cosign. Dependabot cobre Maven, Docker, Actions e Terraform (`.github/dependabot.yml`). A comparação de preço com a região antiga está no documento 08.

1. O pipeline



Build once: o digest publicado em dev é o digest de hml e o de prod. Reconstruir em cada ambiente muda o binário que foi testado. A promoção é troca de tag apontando para o mesmo digest, com aprovação do environment do GitHub em hml e em prod. Dev pode seguir o merge sem aprovação, se o environment existir sem reviewer.

A role de cada ambiente é assumida por OIDC. Não há access key no secret do repositório (ADR 0024). A role de aplicação faz push no ECR daquele ambiente e `UpdateService`. Não faz `DeleteDBInstance`. A role de Terraform é outra.

Região dos workflows: `us-east-1`.

2. O que o pipeline de aplicação faz

Passo	Para quê
`./mvnw verify`	Teste, ArchUnit, integração com Testcontainers. Os dois serviços, em matriz.
JaCoCo	Relatório no artefato do CI. O número não é vaidade: regressão de cobertura no pacote de domínio e no de aplicação é o sinal. Meta de percentual único para o repositório inteiro empurra teste para getter.
Sonar-Cloud	Quality gate no PR: bug, vulnerabilidade, duplicação, e o coverage que o JaCoCo entregou. A ferramenta hospedada evita um SonarQube para operar.
CodeQL	SAST no código e no workflow. Gratuito no repositório público; no privado, cabe na licença do GitHub que o projeto já paga ou não — confirmar antes de tratar como de graça.
Gitleaks	Segredo no diff. Roda antes do build longo.
depen-dency-review	Dependência nova no PR, com o alerta de vulnerabilidade conhecida.
Trivy fs e Trivy imagem	O filesystem pega o que a imagem ainda não tem (Dockerfile, workflow). A imagem ARM64 é o que vai para o ECR. `CRITICAL` e `HIGH` com correção disponível quebram o build. `ignore-unfixed` evita bloquear o que ninguém pode corrigir hoje, e o achado continua visível.
SBOM CycloneDX	Gerado no Maven e anexado ao artefato. Sem SBOM, o Trivy da semana que vem não sabe o que estava em prod.
Cosign	Assina o digest. O deploy recusa imagem sem assinatura verificável. A chave vem de OIDC (keyless, Fulcio) para não criar outro segredo de longa duração.

Actions de terceiro ficam pinadas por SHA. Tag flutuante (`@v4`) é o vetor de supply chain que o resto do pipeline existe para reduzir.

3. O que o pipeline de infra faz

Passo	Para quê
`terraform fmt -check`	Diff legível.
`validate` nos três ambientes, `init -backend=false`	Sintaxe e tipo, sem state.
tflint	Erro de provedor que o validate não vê.

Passo	Para quê
Checkov	Política. Soft-fail é aceitável no primeiro mês, com a lista do que falha virando issue. Soft-fail eterno é não ter a ferramenta.
`terraform test`	Módulo com contrato (nome de fila com prefixo do ambiente, RDS não público, ALB interno). Sem teste, o módulo só quebra no apply.
Infracost	Comentário no PR com o delta de USD/mês. Não bloqueia sozinho: bloqueia se o delta de prod passar de um teto combinado (proposta: USD 50/mês de aumento sem aprovação explícita). O preço de lista do Infracost não substitui o documento 08; ele pega o diff que o documento ainda não viu.

Apply de prod não roda no pull request. Roda no pipeline, no environment `prod`, com aprovação, a partir do merge.

4. O que ainda pode entrar, e por quê

Agrupado pelo motivo. “Porque a banca conhece o nome” não é motivo.

Qualidade

Ferramenta	Motivo para entrar	Quando não
SonarQube self-hosted	O quality gate do SonarCloud já cobre. Self-hosted só se o código não puder sair da rede.	Enquanto SonarCloud for aceitável no DPA. Operar SonarQube para dois serviços é plataforma sem plataforma.
PIT, mutation testing	O teste do domínio (dinheiro, estorno, idempotência) é o lugar em que cobertura mente: asserção fraca passa no JaCoCo. PIT no módulo de domínio, não no repositório inteiro, porque o tempo de mutação no adapter de AWS não devolve o mesmo sinal.	No PR de todo mundo, todo dia, se o tempo passar de poucos minutos. Aí vai para o agendamento noturno.
ArchUnit	Já está no `verify`. Fica. É o que impede o domínio de importar Spring.	—
Pact	O produtor e o consumidor não compilam juntos. O contrato do evento quebra em silêncio até o Compose. Padrões de integração.	Enquanto o fixture compartilhado for um só e o teste da ACL recusar versão desconhecida, o Pact pode esperar o segundo consumidor. No segundo consumidor, deixa de poder.
k6 no pipeline	Sobe o Compose, roda o cenário curto de escrita e o de leitura, falha se o erro passar de 1%. O cenário de 10 minutos não cabe no PR; cabe no agendamento. Documento 05.	Apontado para hml em todo PR, queima tempo e a fatura, e mistura regressão de código com ruído de ambiente.

Segurança

Ferramenta	Motivo	Quando não
OWASP ZAP baseline	DAST no dev ou no Compose, com token de teste. Pega header ausente e rota que não devia existir. Não substitui o teste de BOLA, que é de domínio.	Em prod, e sem um usuário de teste com dado fictício.

Ferramenta	Motivo	Quando não
Semgrep	Regra própria (proibir `comercianteId` vindo do body, proibir log da descrição) mais rápida de escrever do que uma query do CodeQL.	Duplicar o CodeQL sem uma regra que ele não tenha.
Snyk	SCA com o mesmo papel do dependency-review e do Trivy. Um deles, com dono. Dois SCA sem dono geram o mesmo CVE em dois painéis.	Se dependency-review + Trivy já quebram o build no CVE corrigível.
Dependabot ou Renovate	O patch sobe sozinho. Renovate agrupa melhor o BOM do Boot. Dependabot já é o caminho citado no documento 06. O que importa é a regra: Boot 4.1 é recusado enquanto o ADR 0023 mandar.	Bot sem essa regra vira o vetor que furar a matriz de versão.
Prowler ou Security Hub	Postura da conta (trail, bucket público, SG aberto), não do código. Security Hub agrega o que a conta já tem. Prowler é o relatório que se leva para a conversa.	No PR de aplicação. É agendamento da conta.
Cosign + admissão	A assinatura sem alguém que a confira é arquivo. No ECS, o deploy verifica antes do `UpdateService`. No EKS, Kyverno recusa a imagem sem o atestado.	Política de admissão no ECS: não há o hook. A verificação fica no pipeline.

Entrega

Ferramenta	ECS hoje	EKS depois
ArgoCD	não	sim, no mesmo passo do cluster. Repositório de manifests, pull, app-of-apps, drift.
Argo Rollouts	não; o circuit breaker do ECS faz o rollback do rolling	canary com análise de 5xx e de lag, quando o rolling ficar caro
Feature flag (OpenFeature com Unleash, ou AppConfig)	quando a transição do legado precisar desviar um tipo de movimento sem deploy (documento 09)	o mesmo. Flag não é motivo para EKS.
CodeDeploy blue/green no ECS	evolução do ADR 0020, se o rollback do rolling ficar lento e ainda não houver EKS	deixa de ser o caminho; o Rollout assume

Flag sem dono de expiração vira ramo eterno. A flag da transição nasce com data para morrer.

FinOps

Ferramenta	Motivo
Infracost	Delta no PR, já na seção 3.
Kubecost ou OpenCost	Só com nó. No Fargate a conta é a do CUR da AWS, e o Infracost mais a fatura bastam. OpenCost entra com o EKS para ver qual namespace gasta o nó. Kubecost é a distribuição com mais produto em cima; OpenCost é o projeto. Um dos dois.

DORA

Quatro números, tirados do próprio GitHub e do deploy, sem plataforma:

- frequência de deploy (quantos deploys de prod por semana);

- lead time (do merge ao `UpdateService` saudável);
- taxa de falha (deploy que o circuit breaker reverteu, ou hotfix em menos de um dia);
- tempo de restauração (do alarme ao rollout estável).

Com dois serviços, uma planilha mensal chega. Comprar ferramenta de DORA antes de ter doze deploys é medir o vazio. O número serve para a conversa de “estamos com medo de deployar”, não para um painel.

5. ECS e EKS, lado a lado

	ECS, agora	EKS, no gatilho
Artefato	imagem assinada no ECR	a mesma imagem, mais o manifesto no Git
Promo-ção	tag do digest, aprovação, `UpdateService`	commit da tag no repositório de manifests, ArgoCD sincroniza
Rollback	circuit breaker do service, ou deploy da tag anterior	Rollout aborta, ou revert do commit
Política	Checkov no Terraform, Trivy no CI	mais Kyverno no cluster
Segredo	task lê o ARN	External Secrets lê o mesmo ARN
Drift	Terraform plan agendado	ArgoCD, contínuo

O que não se faz na migração: manter o Actions dando `kubectl apply` e o ArgoCD ao mesmo tempo. Dois escritores. O ADR 0028 escolhe o pull.